# CampusLab

## RETO INDEPENDIENTE · MATERIAL DEL ALUMNO

El comité de actividades de un campus ficticio publicó una nueva versión de su portal. Antes de utilizarlo en una actividad, te pide revisar qué información entrega a un visitante y si los recursos que marca como restringidos respetan ese límite.

Tu trabajo es explorar el objetivo, conectar pistas y demostrar los problemas que encuentres con solicitudes reproducibles. A diferencia de la práctica guiada, el enunciado no indica las rutas que debes seguir ni los comandos que debes ejecutar.

## OBJETIVO AUTORIZADO

http://127.0.0.1:8081/

Si el docente anuncia otra URL local, utiliza esa dirección. Trabaja desde Kali. El servidor estará preparado antes de empezar.

## CONDICIONES

- Duración: 90-120 minutos. Trabajo individual o en parejas según indique el docente.

- Herramientas disponibles: navegador, Nmap, curl y Gobuster. Puedes usar rutas_reto.txt como lista de candidatos.

- Puedes inspeccionar HTML, encabezados, JavaScript, archivos públicos y respuestas del objetivo. Si descubres una credencial ficticia, puedes probarla únicamente en este portal.

- Las solicitudes del reto leen información. No se requiere cambiar datos, intentar contraseñas por fuerza bruta ni obtener una consola.

- Para los documentos, limita la exploración a diez identificadores cercanos al documento público que encuentres.

- Resuelve mediante la interfaz HTTP. No se evalúa leer archivos locales del servidor, usar Docker exec ni consultar material del docente.

- Todos los nombres, direcciones de correo, credenciales, cantidades y documentos son ficticios.

## BANDERAS

Hay cuatro marcas con formato CAMPUS{...}. Sirven para confirmar avances. Una bandera sin explicación del recorrido no reemplaza la evidencia.

## Preguntas · 20 puntos

1. (2 puntos) Identifica el puerto del objetivo, el protocolo y el servidor observado. ¿Qué datos puedes confirmar y cuáles serían solo una suposición?

2. (1 punto) Averigua el nombre de la aplicación, su versión declarada y el entorno. Usa dos fuentes diferentes del propio portal.

3. (2 puntos) Construye un mapa con al menos seis rutas o recursos. Incluye su código HTTP y cómo encontraste cada uno. Debe haber al menos una redirección, un recurso denegado y uno inexistente.

4. (1 punto) ¿Qué equipo gestiona el portal y qué correo de contacto publica? Explica qué puedes concluir a partir de esa información.

5. (1 punto) Localiza un rastro de la migración del portal que no aparece en la navegación principal. Registra el recorrido de pistas y la bandera que encuentres.

6. (2 puntos) Encuentra una configuración antigua accesible al visitante. Explica qué información sensible entrega y por qué no debería estar publicada.

7. (2 puntos) Localiza un recurso que exija una credencial y compara tres solicitudes: sin credencial, con una credencial incorrecta y con la recuperada del propio sitio. Incluye estados y evidencias.

8. (2 puntos) ¿Qué acceso conseguiste con la credencial encontrada? Identifica el rol, dos datos que pudiste leer y la bandera. Describe el alcance real de lo demostrado.

9. (3 puntos) Evalúa los controles de acceso de los documentos. Partiendo de un documento público, prueba como máximo diez identificadores cercanos. ¿Puedes leer sin credencial algún documento marcado como restringido? Compara también con otro documento restringido que sí rechace la solicitud.

10. (1 punto) Reúne las cuatro banderas CAMPUS{...} y vincula cada una con su URL y el motivo por el que fue accesible.

11. (2 puntos) Propón correcciones concretas para la configuración expuesta, la credencial reutilizable y el control de acceso a documentos. Explica por qué ocultar enlaces o usar identificadores menos predecibles no sería suficiente.

12. (1 punto) Resume tus dos hallazgos principales. Para cada uno indica condición, pasos mínimos de reproducción, evidencia e impacto. Separa hechos observados de afirmaciones que no probaste.

## Entrega y criterio

Informe de dos páginas como máximo, más un anexo de hasta seis capturas o respuestas HTTP. Agrupa preguntas relacionadas si lo necesitas. Cada bandera debe ir acompañada de su URL y recorrido.

Se evalúa la relación entre observación, prueba y conclusión. Describe únicamente lo que verificaste.